Meridian Studios LLC

Access Controls Policy

Written 2026-09-26 · Exported for Plaid production review 2026-09-26

This document is the access controls policy of Meridian Studios LLC (the "Company"). It states who and what may access the Company's production systems and the consumer financial data they hold, by what means, and how that access is reviewed. It accompanies the Company's Information Security Policy and is maintained in the product's version-controlled repository alongside the code it describes; when the system changes, this document is updated in the same commit.

Every statement in this document is accurate as written, or names a planned change and its date.

1. Scope and principles

1.1 Scope. The policy covers the production server (one DigitalOcean droplet), the Postgres database on it, the third-party consoles that govern them (DigitalOcean, Plaid, Stripe, GitHub, Apple), the secrets that open any of these, and the consumer-facing application itself.

1.2 Principles. Access is granted to the minimum set of people and systems that the service requires, by the strongest practical mechanism, and every grant is enumerable: this document names each one. Production data is not read for debugging or support; this is standing policy, not convenience.

2. Personnel access

2.1 Organization. The Company is operated by one person, Gaetan Almela, who is the developer, the operator, and the security officer. No other person holds any access of any kind. There are no contractors, support staff, or shared accounts.

2.2 Provisioning and de-provisioning. Because there is no one else, there is no onboarding or offboarding process to operate. Should the Company ever grant access to a second person, this policy will be revised first — with named roles, per-person credentials, and a documented revocation step — and the revision will precede the grant.

3. Access to production systems

3.1 The server. SSH to the production server is by key only, from one authorized machine. Password and keyboard-interactive authentication are disabled, and root login is disabled. There is no other interactive door into the server.

3.2 The database. Postgres listens on loopback only and is reachable solely from the application on the same host; it is not exposed to the network. The application authenticates with a password carried over TLS verified against a private certificate authority (`sslmode=verify-full`), so a downgraded or unauthenticated connection is refused.

3.3 Administrative consoles. The DigitalOcean, Plaid, Stripe, GitHub, and Apple consoles each require a second factor. DigitalOcean is entered through Google sign-in, so its second factor is that of the Google account, which has 2FA enabled and is treated as an access point of the same rank as the console it opens. Every point of access was reviewed 2026-09-23.

3.4 No support tooling. There is no admin panel and no support tooling that reads customer data. Debugging proceeds from logs — which strip credentials and never carry customer financial records — not from production reads. Every response that does serve customer data to its owner is recorded in an append-only audit table stating whose data, what data, from what address, and when.

3.5 Physical access. Production hardware is owned and operated by DigitalOcean in its data centers; physical access control is delegated to DigitalOcean and inherited from its compliance program. No production data resides on Company premises apart from an encrypted offline backup copy.

4. Secrets

4.1 Storage. The server's secrets live in an environment file on the server, readable only there. The token-sealing key, the backup encryption key, the Plaid secret, and the Postgres password are escrowed in a password manager, apart from the data they protect.

4.2 Sensitive data. Plaid access tokens — the credential that reads a bank — are sealed with AES-256-GCM at the application level before they reach the database, so database access alone does not expose them.

5. Consumer access

5.1 Authentication. A consumer signs in with a six-digit code emailed to their address, valid for ten minutes and five attempts, exchanged for a bearer token presented in the `Authorization` header only — never in a URL or cookie. Tokens are stored server-side as hashes. The application does not currently offer consumers a second authentication factor.

5.2 Authorization. Every authenticated request is scoped to the requesting account; there is no cross-account read path. Linking a bank additionally requires an active paid subscription, and the number of bank connections held is capped, so exposure grows only with paying customers.

5.3 Destructive actions. Account deletion — the ledger, the bank connections, and the billing record — requires a fresh emailed confirmation code, so a stolen session alone cannot destroy an account.

6. Non-human access

6.1 Outbound. The application authenticates to Plaid, Stripe, and the email provider with per-service secret keys held as described in section 4.

6.2 Inbound. Webhooks are verified cryptographically before they are acted on: Plaid webhooks by ES256 JWT against Plaid's published keys, Stripe webhooks by HMAC signature, and Apple notifications as JWS chains verified against Apple's pinned root certificate. Unverified calls are refused.

7. Review

Access — every door, every credential, every console — is reviewed at each Plaid milestone and at least yearly, and the review is dated. The most recent full review was performed 2026-09-23. Any change to the set of people, machines, or services with access is reflected in this document in the same commit that makes the change.